

La oferta del experto sin contrato

PF1495 · Hacking Ético en Aplicativos Web
Módulo 2 · MA03807 · Introducción al hacking ético

MODALIDAD

Individual.

APRENDIZAJE ESPERADO 2

Analizar las características del hacking ético, código ético, marco legal y normas de la industria para la protección de los sistemas informáticos.

CRITERIOS DE EVALUACIÓN

- 2.1 Identifica las características principales del hacking ético, principios y principales metodologías y certificaciones de la industria.
- 2.2 Describe el marco legal y ético al cual se circunscriben las prácticas del hacking ético identificando las principales leyes relacionadas con la protección de datos.
- 2.3 Explica las principales características y alcances de las normas y estándares de la industria para el hacking ético

Contexto

Agencia de Viajes Rumbo Sur (empresa ficticia) recibió este correo de un experto independiente:

«Soy hacker ético certificado. Ya hice un escaneo rápido de su sitio y encontré fallas graves. Puedo empezar el lunes sin contrato: basta con que me den la clave del panel. Guardaré una copia de su base de clientes como respaldo. Si no aceptan, publicaré las fallas para alertar a sus clientes.»

La gerente quiere saber si es una buena oferta y qué debería exigir a quien pruebe su sitio.

Qué tienes que hacer

- 1. Qué es y qué no es hacking ético (criterio 2.1).** Identifica cuatro principios del hacking ético que el correo no respeta y explica cada uno en 1 a 2 líneas. Luego indica qué acredita una certificación de la industria (por ejemplo, CEH u OSCP) y qué no reemplaza, y nombra dos metodologías que la agencia podría pedir que se usen.
- 2. Marco legal y ético (criterio 2.2).** En una tabla, relaciona el correo con las normas que podrían aplicar en Chile: la Ley 21.459 de delitos informáticos (acceso no autorizado), la ley de protección de datos personales (Ley 19.628, reformada por la Ley 21.719), la de propiedad intelectual (Ley 17.336) y el Convenio de Budapest como tratado de cooperación internacional. No cites artículos: explica qué protege cada una y qué conducta del correo

toca. Agrega qué compromiso de los códigos de ética de EC-Council o del Instituto SANS rompe la amenaza de publicar las fallas.

- 3. Normas y estándares (criterio 2.3).** Explica en una tabla para qué sirve ISO/IEC 27001, NIST SP 800-53 y la guía de pruebas de OWASP (OWASP TG), y cuál le recomiendas a la agencia para ordenar una prueba de su sitio web.
- 4. Respuesta a la gerente.** Redacta en 5 a 8 líneas las condiciones mínimas que la agencia debería exigir antes de autorizar una prueba.

Entrega

Sube a esta Tarea un documento PDF de 1 a 2 páginas con tus respuestas a los puntos 1 a 4, incluidas las dos tablas y las fuentes que consultaste.